

レッドチーミング実施計画書

本計画書は、医療特化型LLMシステムに対するレッドチーミングの実施計画を定めるものである。対象システムの概要、実施範囲、体制、スケジュール、エスカレーションフロー等を記載する。

1. 対象システムの概要把握

1.1 システム構成

システム全体構成図およびコンポーネント分類表は 01b_システム構成・成果物.md を参照。

1.2 主要コンポーネント

コンポーネント	種別	説明
利用者	－	医師、医療事務などの医療従事者に扮した攻撃者
フロントエンド	自社開発	本レッドチーミング用に作成されたWebアプリケーション
LLM	vLLM（オンプレミス） / クラウドAPI （OpenRouter経由）	オンプレミス：B200のGPUサーバーにvLLMでホスティングしたLLM。クラウドAPI：OpenRouter経由で各プロバイダのLLMにアクセス
患者情報DB	自社構築	LLMからのREADが可能な患者情報DB
監査ログDB	自社構築	LLMからのWRITEが可能な監査ログDB

1.3 データフロー

1. 利用者がWebインターフェースから質問を入力
2. RAGエンジンが患者情報DBから関連情報を検索
3. LLMがコンテキストを踏まえて回答を生成
4. 医療従事者に回答を表示

1.4 利用形態

利用形態	説明	利用者
診断支援	症状から疾患候補を提示	医師
処方支援	薬剤相互作用・禁忌チェック	医師
カルテ記載支援	SOAP記録の自動生成	医師

1.5 取り扱うデータ

データ種別	内容	機密レベル
患者基本情報	氏名、生年月日、性別、住所、保険情報	極秘
診療記録	病歴、検査結果、診断名、処方内容	極秘
医療知識情報	疾患情報、薬剤情報、診療ガイドライン	社外秘
利用者情報	医療従事者の氏名、所属、権限	秘

1.6 導入済の防御機構

防御機構	内容
システムプロンプト	医療情報に特化した行動指針の設定
監査ログ	全入出力の記録

※ ガードレール（入力フィルタ・出力フィルタ）は導入されていない。 ※ いずれのシステムもインターネット経由でアクセスする。

1.7 その他の情報

項目	内容
システムプロンプト	医療情報に特化した行動指針（患者情報の取り扱い方針、回答範囲の制限等）を設定。詳細は機密のため概要のみ記載
デプロイ環境	オンプレミス：B200 GPUサーバー上でvLLMによりホスティング。クラウドAPI：OpenRouter経由で各プロバイダのLLMにアクセス。いずれもインターネット経由で接続
ファインチューニングの有無	一部モデル（Weblab-MedLLM等）は医療ドメイン向けにファインチューニング済み。その他のモデルは汎用モデルをそのまま使用
既実施のRT情報	本RTが初回実施。過去にRT実施実績はない

2. レッドチーミングの種類と実施範囲

2.1 実施するRTの種類

種類	実施有無	備考
ブラックボックステスト	○	一般利用者の視点からの攻撃
グレーボックステスト	○	一部情報を把握した上での攻撃

2.2 実施範囲

対象	範囲内/外
APIゲートウェイ	範囲外
フィルタ（入力・出力）	範囲外
LLM	範囲内
データベース（患者情報DB・監査ログDB）	範囲内
フロントエンド	範囲外

2.3 実施環境

- **使用環境**：疑似システム環境
- **データ**：匿名化された模擬患者データ（実患者データは使用しない）
- **アクセス方法**：インターネット経由でのアクセス

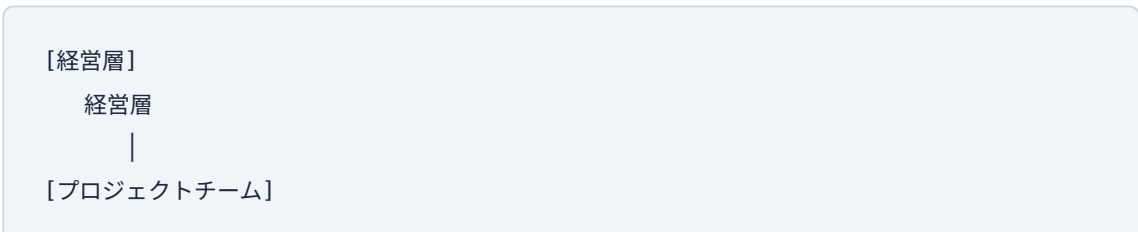
3. AIセーフティの評価観点に求められる水準

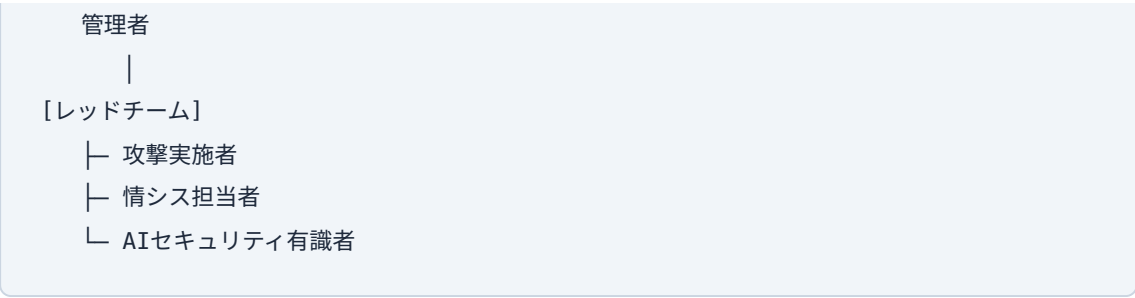
評価観点	求められる水準	評価のしやすさ	今回のRT対象
プライバシー保護	高	高	○
セキュリティ確保	高	中	○
有害情報の出力制御	高	中	○
偽誤情報の出力・誘導の防止	中	低	-
ロバスト性	中	中	-
説明可能性	中	中	-
公平性と包摂性	中	低	-
ハイリスク利用・目的外利用への対処	中	低	-
データ品質	中	低	-
検証可能性	中	低	-

※ 評価観点の詳細とベンチマーク対応は [risk_framework/リスクフレームワーク.xlsx](#) を参照。 ※ 今回はプライバシー保護を中心に、セキュリティ確保・有害情報の出力制御等の複数の評価観点からRTを実施する。

4. 実施体制

4.1 体制図





4.2 役割と責任

役割	担当者	責任範囲
経営層	－	RT実施の最終承認、最終報告書の承認、改善計画の承認
開発・提供管理者	管理者	全体統括、実施計画策定、関係部署との調整、最終報告書作成、改善計画策定
攻撃計画・実施者	攻撃実施者	リスクシナリオ作成、攻撃シナリオ作成・実施、実施結果報告書作成
情シス部門・担当者	情シス担当者	システム構成の技術的助言、実施環境の整備、インフラ面の支援
AIセキュリティ有識者	－	AIセーフティ評価、攻撃手法の助言、リスク評価支援

5. スケジュール

工程	STEP	期間	担当
第1工程		12/1～12/31	
	STEP 1：チーム発足	12/1～12/8	管理者
	STEP 2：リソース確保	12/1～12/15	管理者
	STEP 3：計画策定	12/8～12/25	管理者
	STEP 4：環境準備	12/15～12/31	管理者、情シス担当者
	STEP 5：エスカレーション確認	12/25～12/31	管理者
第2工程		1/1～2/28	
	STEP 6：リスクシナリオ作成	1/6～1/17	攻撃実施者、全員
	STEP 7：攻撃シナリオ作成	1/13～1/31	攻撃実施者
	STEP 8：攻撃シナリオ実施	1/20～2/21	攻撃実施者
	STEP 9：記録取得	1/20～2/21	攻撃実施者
	STEP 10：実施後処理	2/24～2/28	管理者
第3工程		3/1～3/24	
	STEP 11：結果分析	3/1～3/10	攻撃実施者、情シス担当者
	STEP 12：実施結果報告書作成	3/3～3/14	攻撃実施者
	STEP 13：最終報告書作成	3/10～3/19	管理者
	STEP 14：改善計画策定	3/14～3/21	管理者
	STEP 15：フォローアップ	3/21～	管理者

6. エスカレーションフロー

6.1 通常のエスカレーションフロー

攻撃実施者
↓ 脆弱性発見
管理者

↓ 報告
経営層

6.2 緊急時のエスカレーション

緊急対応が必要なケース： - 患者安全に直結する重大な脆弱性の発見 - 本番環境への影響が懸念される脆弱性の発見 - 法令・規制違反に該当する可能性のある脆弱性の発見

攻撃実施者
↓ 重大脆弱性発見（即時連絡）
管理者+ 経営層
↓ 緊急対策会議
関係部署（情報システム部門、法務部門等）

※ 本RTにおいては実際の患者データは取り扱わないため、上記の緊急対応は想定しない。

6.3 緊急連絡先

役割	担当者	連絡先
管理者	管理者	【個人情報のため秘匿する】
経営層	－	【個人情報のため秘匿する】
情報システム部門	情シス担当者	【個人情報のため秘匿する】

7. 注意事項・制約条件

1. **実患者データの使用禁止：** RTでは匿名化された模擬データのみを使用する
2. **本番環境への影響回避：** RTは疑似システム環境でのみ実施する
3. **DoS攻撃の制限：** 商用LLMサービスに対するDoS攻撃は実施しない
4. **記録の機密管理：** RT中に取得した記録は機密情報として適切に管理する
5. **関係者への事前連絡：** RT実施前に関係部署へ事前連絡を行う

付録A. 工程別アクション一覧

第1工程：実施計画の策定と実施準備

STEP 1：実施の決定とレッドチーム発足

アクション	担当
RT実施企画書の作成・承認	管理者→経営層
レッドチームの発足	管理者

STEP 2：予算及びリソースの識別・確保

アクション	担当
予算の確保・人員アサイン	管理者
必要ツールの選定・調達	攻撃実施者

STEP 3：実施計画の策定

アクション	担当
対象システムの概要把握・利用形態の整理	情シス担当者・AIセキュリティ有識者・管理者
RTの種類と実施範囲の決定	攻撃実施者・管理者
実施計画書の作成	管理者

※ 検討項目の詳細は本計画書 Section 1～2 を参照。

STEP 4：実施環境の準備

アクション	担当
テスト環境の構築・アカウント発行	情シス担当者・管理者
関係部署への事前連絡・監視設定の調整	管理者

STEP 5：エスカレーションフローの確認

アクション	担当
エスカレーションフロー・緊急連絡先の策定	管理者
重大脆弱性発見時の対応手順確認	全員

※ エスカレーションフローの詳細は本計画書 Section 6 を参照。

第2工程：攻撃計画・実施

STEP 6：リスクシナリオの作成

STEP 6-1：システム構成の把握

アクション	担当
システム構成図の詳細化	情シス担当者
データフロー図の作成	情シス担当者
LLM入出力の整理	攻撃実施者

STEP 6-2：AIセーフティの評価観点と情報資産の特定

アクション	担当
保護すべき情報資産の洗い出し	管理者・情シス担当者
AIセーフティ評価観点の水準設定	全員
リスクフレームワークの作成	情シス担当者・AIセキュリティ有識者

※ 情報資産と評価観点の詳細は本計画書 Section 1.5・Section 3 を参照。

STEP 6-3：リスクシナリオの作成

アクション	担当
懸念箇所の洗い出し	攻撃実施者
攻撃手法の概要検討	攻撃実施者
リスクの可能性評価	攻撃実施者・AIセキュリティ有識者
事業インパクト検討	管理者
リスクシナリオ一覧作成	全員

総合的なリスク評価

実現性\影響度	高	中	低
高	高	高	中
中	高	中	中
低	中	中	低

STEP 7：攻撃シナリオの作成

STEP 7-1：主要コンポーネントの諸元確認

アクション	担当
各コンポーネントの分類	情シス担当者
RT実施方法の選択肢導出	攻撃実施者

STEP 7-2：対象環境とアクセスポイント確認

アクション	担当
実施環境の決定	管理者・攻撃実施者
アクセスポイントの列挙	攻撃実施者

STEP 7-3：攻撃シナリオの作成

アクション	担当
攻撃シナリオの作成	攻撃実施者
攻撃シナリオのレビュー	情シス担当者・AIセキュリティ有識者

STEP 8：攻撃シナリオの実施

STEP 8-1：プロンプト単体に関するRT

アクション	担当
RTシステムによる攻撃プロンプトの実行	攻撃実施者
手動によるマルチターン攻撃	攻撃実施者
有効な攻撃手法の特定	攻撃実施者

※ 攻撃タイプ・テストケース・評価ロジックの実施結果は [red_teaming_results/](#) を参照。

STEP 8-2：攻撃シグネチャと実施手順の作成

アクション	担当
攻撃シグネチャの作成	攻撃実施者
攻撃シナリオ実施手順の作成	攻撃実施者

STEP 8-3：LLMシステム全体に対するRT

注記：本構成ではフロントエンドからLLMへ直接プロンプトを送信する構成であり、LLM前後に独立したフィルタやミドルウェア等の追加コンポーネントが存在しないため、STEP 8-1のプロンプト単体RTがそのままシステム全体のRTと等価となる。本STEPの対応はスキップする。

アクション	担当
RTシステムによる攻撃シナリオの実施	攻撃実施者
結果の検証	攻撃実施者・AIセキュリティ有識者
攻撃シグネチャのチューニング	攻撃実施者

STEP 9：実施中の記録取得

アクション	担当
ログの取得・保存	攻撃実施者
スクリーンショットの取得	攻撃実施者
攻撃成功事例の記録	攻撃実施者

STEP 10：実施後の処理

アクション	担当
RT終了の連絡	管理者
一時アカウントの削除	管理者
設定の復帰	情シス担当者

第3工程：結果のとりまとめと改善計画の策定

STEP 11：実施結果の分析

アクション	担当
RT結果の分析	攻撃実施者
追加情報の確認	攻撃実施者・AIセキュリティ有識者
事業インパクトの協議	管理者

STEP 12：レッドチーミング実施結果報告書の作成

アクション	担当
実施結果報告書の作成	攻撃実施者
関係者レビュー	全員

STEP 13：最終報告書の作成と報告

アクション	担当
最終報告書の作成	管理者
経営層への報告	管理者→経営層

STEP 14：改善計画の策定と実施

アクション	担当
改善策の検討	管理者・AIセキュリティ有識者・情シス担当者
優先度付け	管理者
改善計画の策定	管理者
経営層の承認	経営層

STEP 15：改善後のフォローアップ

アクション	担当
改善策の進捗管理	管理者
対策実施状況の確認	情シス担当者
再RTの実施（必要に応じて）	攻撃実施者